

Lesson 4: HEALTHCARE INFORMATION SYSTEMS (HIS) RISK ASSESSMENT

ISO 27005
Organizational
Context Input

ISO 27005

A MERGED APPROACH:
ISO 27005 & NEN-7510:2024
(A Powerful Team!)

NEN 7510:2024

NEN 7510:2024
Care Sector
Context Input

ISO 27005

NEN 7510:2024

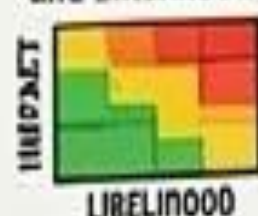
PERIMETER
SECURITY
MULTI-FACTOR
AUTH (MFA)

ACCESS CONTROL
(LEAST PRIVILEGE)
CYBER SECURITY
TRAINING

② IDENTIFY HIS RISKS:
• Assets (EHR Data,
Medical Devices)
[NEN/ISO]
• Threats
(Phishing, Failure)
• Vulnerabilities

⑥ EVALUATE RISKS:
Compare to Internal
Mitigation Measures

③ ANALYZE RISKS:
Assess impact
(to Patient Care,
to Data Privacy)
and Likelihood



LIKELIHOOD

④ EVALUATE RISKS:
Compare to internal
risk acceptance criteria
and regulatory
standards



⑤ TREAT RISKS:
Develop combined
Mitigation Measures

⑥ MONITOR:
Review & Continuous
Improvement

REGULATORY FINE
(GDPR/AVG)

LEGAL
ACTION

BUSINESS
CONTINUITY PLAN

PATIENT HARM
(CLINICAL ERRORS)

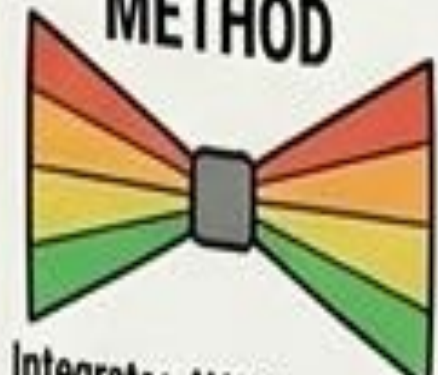
REPUTATIONAL
LOSS

Little
'Analyzed
Risk' balls

RISK IN HIS:
Not a checkbox.
A continuous process!



VISUALIZING
HIS RISK:
THE BOW-TIE
METHOD



Integrates AVG Compliance
& HIS Beveiliging

SEC GPS
BARRY

NEN 7510:2024
COMPLIANCE
GUIDELINE

AIRPORT &
ACCEPTANCE
CHECKLIST



EXTERNAL
MALWARE



INTERNAL
MISUSE



THIRD-PARTY
FAILURE



HEALTHCARE RISK ASSESSMENT

WAAR STAAN WE

Workshop	Thema	Deliverable
WS01	Wet- & regelgeving, NEN-7510, audit mindset	Begrippenkader
WS02	Hardening CI/CD pipeline (CodeQL, Dependabot, SBOM)	Beveiligde pipeline
WS03	Healthcare Risk Assessment (risicomatrix, bow-tie)	Risicorapport
WS04	Compliance Scanning (CVE/CVSS, Snyk, security backlog)	Scanrapport + backlog
WS05	Secure Coding & Privacy by Design	Logging + tests
WS06	Formeel auditrapport	Definitief auditrapport

AGENDA

- Terugblik WS02
- Waarom risicomanagement
- De hack-driehoek: kroonjuwelen, kwetsbaarheden en kwaadwillenden
- Risico definitie
- Risicomatrix
- Risicobeheersing: de vier opties
- Methodiek: ISO 27005 en NEN-7510
- Bow-tie analyse
- Koppeling met NEN-7510:2024-2
- Opdrachten

LEERDOELEN

Na deze workshop kun je...

- ✓ Uitleggen wat een risico is en hoe je het berekent (kans × impact)
- ✓ Dreigingsactoren en aanvalsmotieven benoemen en vertalen naar een healthcare-context
- ✓ Een risicomatrix opstellen en risico's prioriteren op basis van kans en impact
- ✓ De vier risicobeheersingsstrategieën toepassen op concrete gevallen
- ✓ ISO 27005 als procesraamwerk gebruiken voor een gestructureerde

risicoanalyse

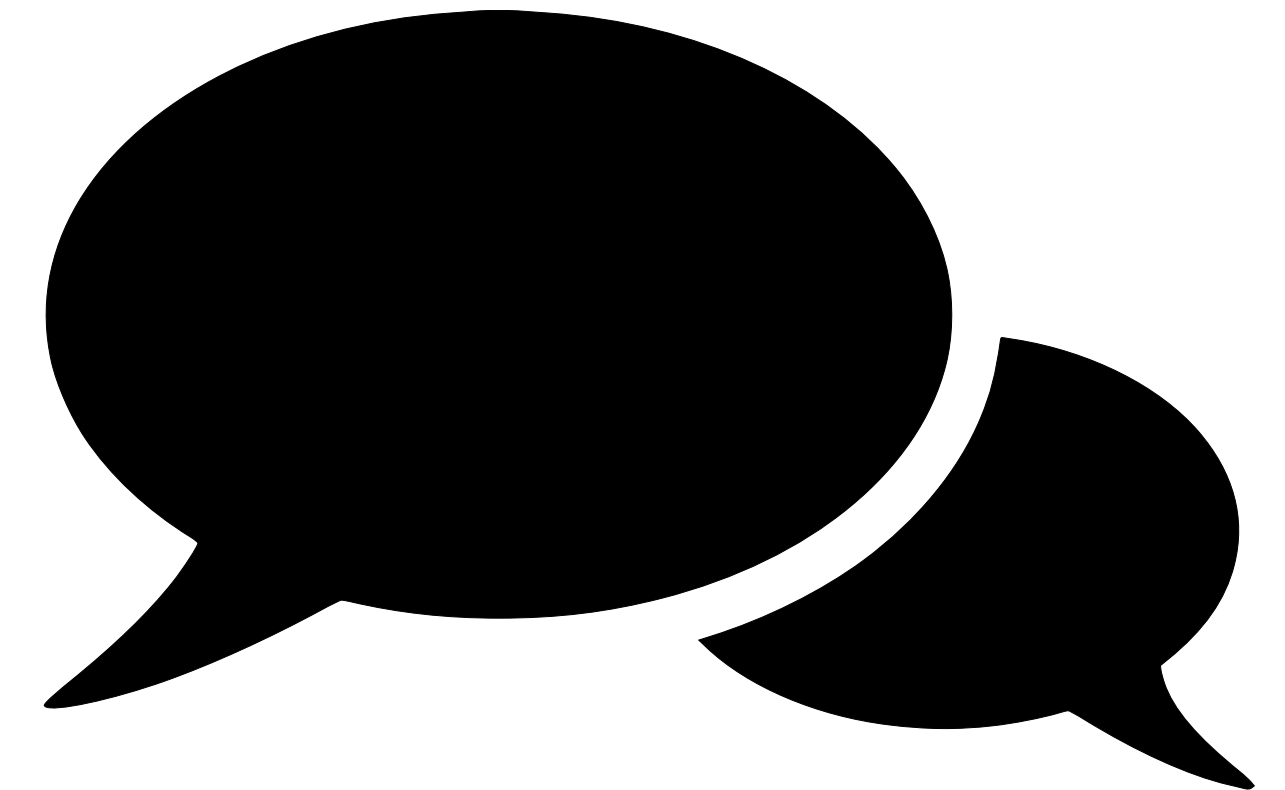
avans
hogeschool

- ✓ Het MAPGOOD-model inzetten om risicobronnen systematisch in kaart te

Terugblik WS02

Je hebt een 'hardened' pipeline – is het systeem nu veilig?

- Branch protection, SAST, SCA, SBOM, OTAP-omgevingen
 - Verminderd risico's (LET OP: geen eliminatie!)
- Gelinkt aan NEN-7510:2024 deel 2 controls
- Welke controls?
- Andere principes?
 - Least privilege?
 - Defense in Depth?
 - AuthN / Z in project omgeving?



MIA (tot nu toe)

- Systematisch in kaart brengen welke risico's er überhaupt zijn
- Beslissen welke risico's we accepteren en welke we moeten aanpakken
- Aantonen dat de gekozen maatregelen proportioneel zijn aan de risico's

NEN-7510-1 (6.1.2) vereist expliciet een risicoanalyse als grondslag voor het ISMS

- *ISMS: Information Security Management System
- *We gaan niet diep in op deel 1 maar risicoanalyse is belangrijk
- "De organisatie moet informatiebeveiligingsrisico's identificeren, analyseren en beoordelen."
- "Een product zonder risicoanalyse is bouwen zonder plan"

Risico management | Waarom

- 100% veiligheid bestaat niet — maar 0% inspanning is ook geen optie
- Medische gegevens:
 - bijzondere persoonsgegevens, strengste categorie (AVG art. 9)
- Patiëntveiligheid en continuïteit zijn beide kritisch
- Juridische verplichting:
 - CRA, NIS2/CBW, NEN-7510, ISO 27001
 - eisen een risico gebaseerde aanpak
- Ethische verantwoordelijkheid:
 - een bug in b.v. een doseermodule kan dodelijk zijn
 - Datalek gevoelige gegevens kan bij betrokkenen serieuze consequenties veroorzaken

Risico management | Wat het oplevert

"Je kunt niet alles beveiligen. Risicoanalyse helpt je te kiezen waarmee je begint."

- Zicht op wat je moet beschermen en waartegen
- Onderbouwde keuzes
 - waarom kies je maatregel A in plaats van B?
- Aantoonbaarheid richting IGJ, auditors en opdrachtgevers
- Proportionaliteit
 - je investeert in beveiliging waar het er het meest toe doet

HACK-DRIEHOEK

Een hack kan alleen plaatsvinden op het moment dat aan alle drie de voorwaarden voldaan is.

Dit kunnen we gebruiken ter verdediging.



Hack driehoek

Hoek	Betekenis	Verdedigingsstrategie
Kroonjuweel	Wat heeft waarde voor een aanvaller?	Identificeer en classificeer assets
Kwetsbaarheid	Hoe kan een aanvaller binnenkomen?	Patch, hardening, secure coding
Kwaadwillende	Wie wil aanvallen en waarom?	Threat modeling, monitoring



Defender logic:

Verwijder één hoek van de driehoek → aanval mislukt.

Je kunt de kwaadwillende niet controleren, maar je kunt kroonjuwelen beschermen en kwetsbaarheden wegwerken.

Quote time | Art of war

Know Your Enemy

Understand their motives, strengths, weaknesses, and strategies.

Know Yourself

Be aware of your own capabilities, limitations, and resources.

Strategic Advantage

By knowing both sides, you can position yourself where you are strong and your opponent is weak.



DE TEGENSTANDER AKA KWAADWILLENDE

Bron: ENISA – European Union Agency For Cybersecurity

Wie zijn de kwaadwillende die 'jouw' systeem willen aanvallen?

*APT – Advanced Persistent Threat

avans
hogeschool

Georganiseerde misdaad / cybercriminelen

Geld is het grootste en enige motief

Statelijke actoren (state sponsored actors / APT*)

Vaak militaire doelstellingen voor statelijk gewin, zoals spionage, politieke manipulatie, (industriële) sabotage, maatschappelijke ontwrichting (disruption and destruction).

Hacktivists

Hackers met activistische doelstelling. Statelijke actoren schuilen zich ook vaak achter activistische motieven om geen oorlog uit te lokken.

Script kiddies

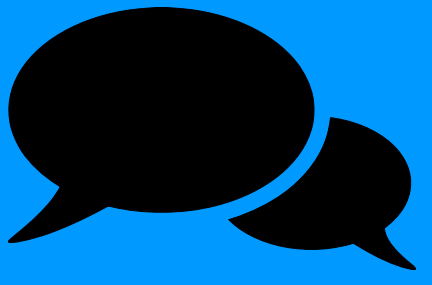
Vaak eenlingen die mogelijkheden aan het verkennen zijn voor fun en opbouwen van vaardigheden. Kunnen al wel criminele activiteiten zijn.

Insider threats

Ontevreden medewerkers, omkoping van medewerkers, medewerkers met een kwaadwillende motivatie.

Ken de tegenstander

Type	Motivatie	Kenmerk	Relevantie voor zorg
Cybercriminelen	Financieel gewin	Professioneel, georganiseerd	Ransomware op ziekenhuissystemen
Statelijke actoren (APT)	Spionage, sabotage, maatschappelijke ontwrichting	Geavanceerd, langdurig, goed gefinancierd	Aanvallen op kritieke infrastructuur
Hacktivisten	Politiek / ideologisch statement	Variabel niveau; statelijke actoren schuilen hier soms achter	Lekken van patiëntdata als protest
Script kiddies	Fun, skills oefenen	Laag niveau, opportunistisch	Kansen grijpen bij bekende CVE's
Insider threats	Ontevredenheid, geld, ideologie	Moeilijk te detecteren; heeft al toegang	Medewerker die dossiers raadpleegt buiten behandelrelatie



Ken jezelf | De Kroonjuwelen

Niet alles is even waardevol — focus op wat echt telt

- Wat zijn kroonjuwelen?
- Welke kroonjuwelen heeft een ziekenhuis dat OpenMRS gebruikt?
- Wat zijn kroonjuwelen die bij Avans liggen?
- Op welke manieren kunnen deze kroonjuwelen gestolen worden?

kroonjuwelen in een healthcare-omgeving

Asset	Type	Dreigingsscenario
Patiëntdossiers	Data (vertrouwelijkheid)	Datalek, verkoop op darkweb
Medicatiegegevens	Data (integriteit)	Manipulatie → verkeerde dosering
EPD-beschikbaarheid	Systeem (beschikbaarheid)	Ransomware → zorgprocessen liggen stil
Gebruikerscredentials	Data (vertrouwelijkheid)	Overname accounts, ongeautoriseerde toegang
Broncode (OMRS modules)	Intellectueel eigendom	Supply chain attack
Audit logs	Data (integriteit)	Verwijderen van bewijs na incident

RISICOANALYSE

Een cyberrisicoanalyse is een structureel proces waarin de aanwezige cyberrisico's in kaart worden gebracht.

Alleen nadat deze risico's geïdentificeerd zijn, is het mogelijk om effectieve maatregelen te definiëren en te begrijpen. De eerste stap dus!

Risico's zijn onzekere gebeurtenissen in de toekomst die invloed kunnen hebben op jouw onderneming.



Wat is een risico?

- Een risico is de **kans** dat een bepaalde **gebeurtenis** plaatsvindt met een bepaalde (negatieve) **impact**.
- **Risico = Kans x Impact**
- **Kans = Blootstelling x Waarschijnlijkheid**
 - Blootstelling: is de kwetsbaarheid aanwezig en bereikbaar?
 - Waarschijnlijkheid: hoe groot is de kans dat een kwaadwillende deze benut?
 - Impact: ernst van de gevolgen voor de CIA-triad
 - vertrouwelijkheid, integriteit, beschikbaarheid

Wat is een risicobron?

- **Een risicobron (hazard) is een bron van gevaar.**
- Een gevaar is elke bron van potentiële schade, schade of nadelige gevolgen voor de gezondheid van iets of iemand.
 - Denk aan gevaar voor de gezondheid, van verlies van eigendommen of apparatuur, of voor het milieu.



Risico voorbeeld

- Blootstelling:
 - OpenMRS API-endpoint zonder rate limiting (kwetsbaarheid aanwezig)
- Waarschijnlijkheid:
 - BOLA-aanval is een bekende techniek (OWASP API Top 10 #1)
- Impact?
 - massale extractie van patiëntdossiers (hoog: AVG-boete + reputatieschade)
- Risico = Hoog



CIA (BIV) triad | Impact

Dimensie	Vraag	Healthcare-voorbeeld
Confidentiality (Vertrouwelijkheid)	Kan onbevoegden toegang krijgen tot de data?	Patiëntdossier ingezien door niet-behandelend arts
Integrity (Integriteit)	Kan de data ongemerkt gewijzigd worden?	Medicatie dosering aangepast in het EPD*
Availability (Beschikbaarheid)	Kan het systeem of de data onbereikbaar worden?	Ransomware legt het EPD plat tijdens een operatie

Ook:

- Financiële schade
- Schade aan personen / gezondheid
- Reputatieschade
- Juridische gevolgen (boetes, sancties)
- Operationele gevolgen (continuïteit)

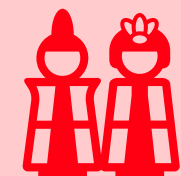
RISICOANALYSE STAPPENPLAN



Bepaal wat je wil beschermen (assetlijst)



Identificeer de risico's



Analyseer de gevonden risico's (risicoregister)



Besluit wat je gaat doen: accepteren, oplossen (of mitigeren), overdragen of stoppen.

RISICOMATRIX

Impact	Kans				
	Ze er onwaarschijnlijk	onwaarschijnlijk	Mogelijk	Waarschijnlijk	Ze er waarschijnlijk
Onbelangrijk					
Minder ernstig					
Serieus					
Ze er serieus					
Catastrofaal					

Codering:

- **Rood (≥ 15):** onacceptabel risico
 - onmiddellijk aanpakken
- **Oranje (8-14):** verhoogd risico
 - mitigatieplan met deadline
- **Groen (≤ 7):** acceptabel
 - monitoren en periodiek herbeoordelen

Risico prima Voor dit risico hoeven geen (extra) maatregelen getroffen worden.	Risico acceptabel Alleen acceptabel als voor het risico reeds maatregelen zijn getroffen. Bij een initieel geel risico maatregelen treffen.	Risico te hoog Risico kan niet worden geaccepteerd. Maatregelen moeten getroffen worden om deze verder te reduceren.	Risico niet aanvaardbaar Voor dit risico moet direct maatregelen getroffen worden of het risico dient vermeden te worden als het lastig te mitigeren blijkt.
--	---	--	--

SECURITYMAATREGELEN (SECURITY CONTROLS)

	Kans				
Impact	Ze er onwaarschijnlijk	onwaarschijnlijk	Mogelijk	Waarschijnlijk	Ze er waarschijnlijk
Onbelangrijk					
Minder ernstig		X'			
Serieus					
Ze er serieus					
Catastrofaal			Kans verlagen	X	

Impact verlagen

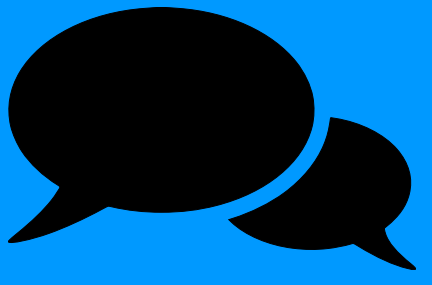
Risico beheersing:

- Accepteren
- Oplossen (of mitigeren)
- Overdragen
- Ontwijken

Mitigeren:

- Kans reducerende maatregelen
- Impact reducerende maatregelen

RISICOMATRIX KANS EN IMPACT



- Hoe bepaal je de kans?
- Hoe bepaal je de impact?

Impact	Kans				
	Ze er on wa ars chijn lijk	on wa ars chijn lijk	Mo ge lijk	Wa ars chijn lijk	Ze er wa ars chijn lijk
On be lang rijk					
Min der ern stig					
Se rieus					
Ze er se rieus					
Cata stro faal					

RISICOMATRIX IMPACT

- Financiële schade
- Schade aan personen en/of gezondheid
- Reputatieschade
- Schade aan omgeving
- ...

Risico, en dan?

Na de analyse: wat doe je met een risico?

Strategie	Wanneer	Voorbeeld
Vermijden	Risico is te groot; activiteit stopt of wordt anders ingericht	Geen productiedata in testomgevingen gebruiken (stop het risico bij de bron)
Verminderen (mitigeren)	Risico is te groot maar activiteit is noodzakelijk	MFA implementeren vermindert kans op accountovername
Overdragen	Risico is acceptabel maar beter bij een andere partij	Cyberrisicoverzekering; SLA met clouddienst voor beschikbaarheid
Accepteren	Risico is klein genoeg én kosten van aanpak > verwachte schade	Laag-risico kwetsbaarheid bewust accepteren mits gedocumenteerd

Risico strategie

Let op: accepteren is nooit "niets doen en vergeten".

Vereist:

- **Documentatie** van de beslissing (wie, wanneer, waarom)
- **Periodieke** herbeoordeling
- **Goedkeuring** op het **juiste** niveau

NEN-7510 eis: risicobehandeling moet worden gedocumenteerd en goedgekeurd (kern van ISMS (deel 1))

Risico assessment en NEN-7510

- 100% veiligheid is dus erg lastig
 - (en: hoe bewijs je de afwezigheid van vulns?)
- NEN-7510 eist een aanpak o.b.v. risicoanalyses
- Maar NEN-7510 zegt NIET welke aanpak
 - ISO-27005 gebruiken
 - Sluit perfect aan
 - Gestructureerd proces (raamwerk)
- Note:
 - NEN Connect biedt een aantal tools aan om te helpen met risico inventarisatie en beheer

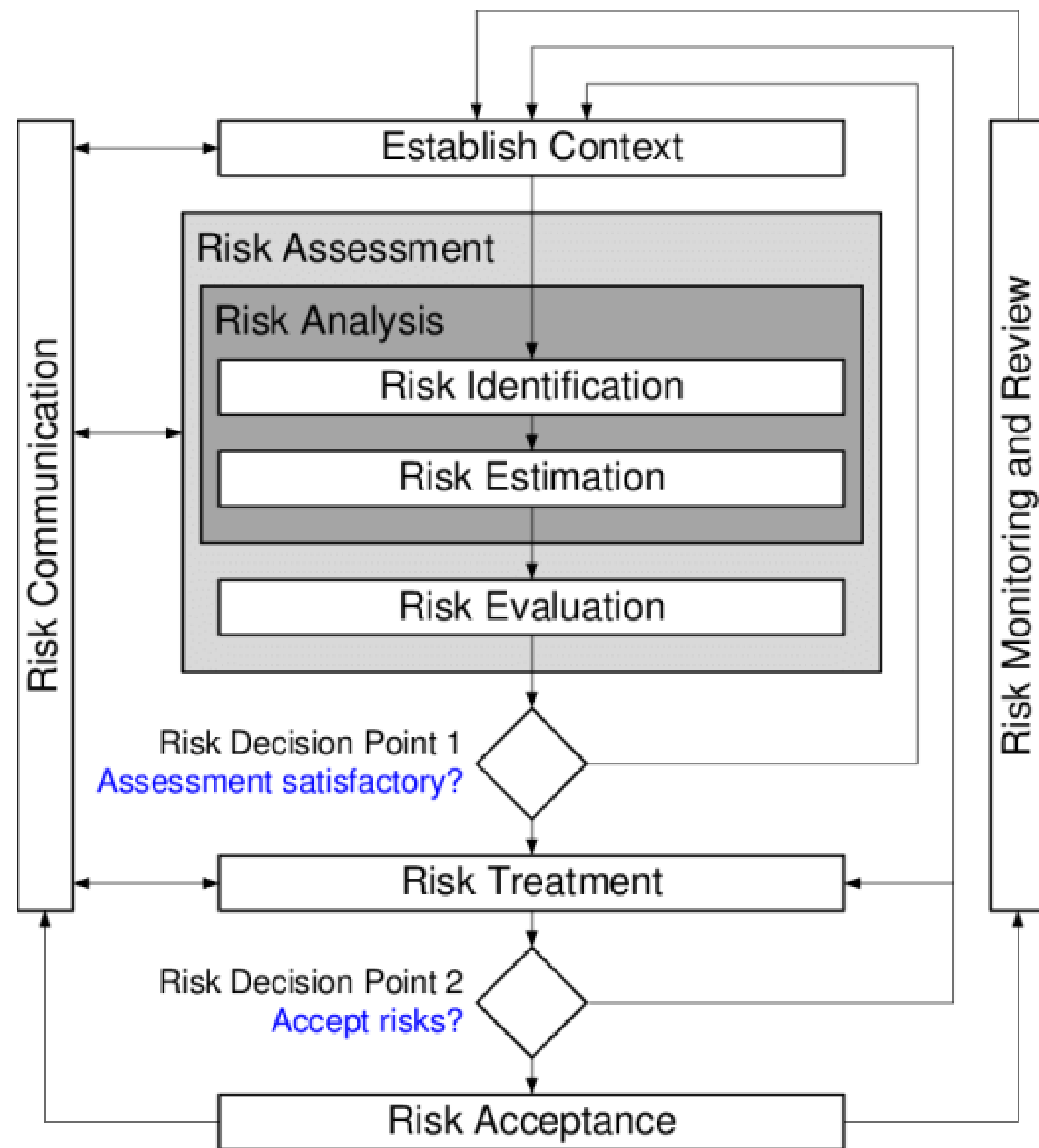


RISICO- ASSESSMENT

Methodiek om de risico's te identificeren en het bepalen van de grootte van het risico (kans x impact).



ISO/IEC 27005 Risk management Process *avans* hogeschool



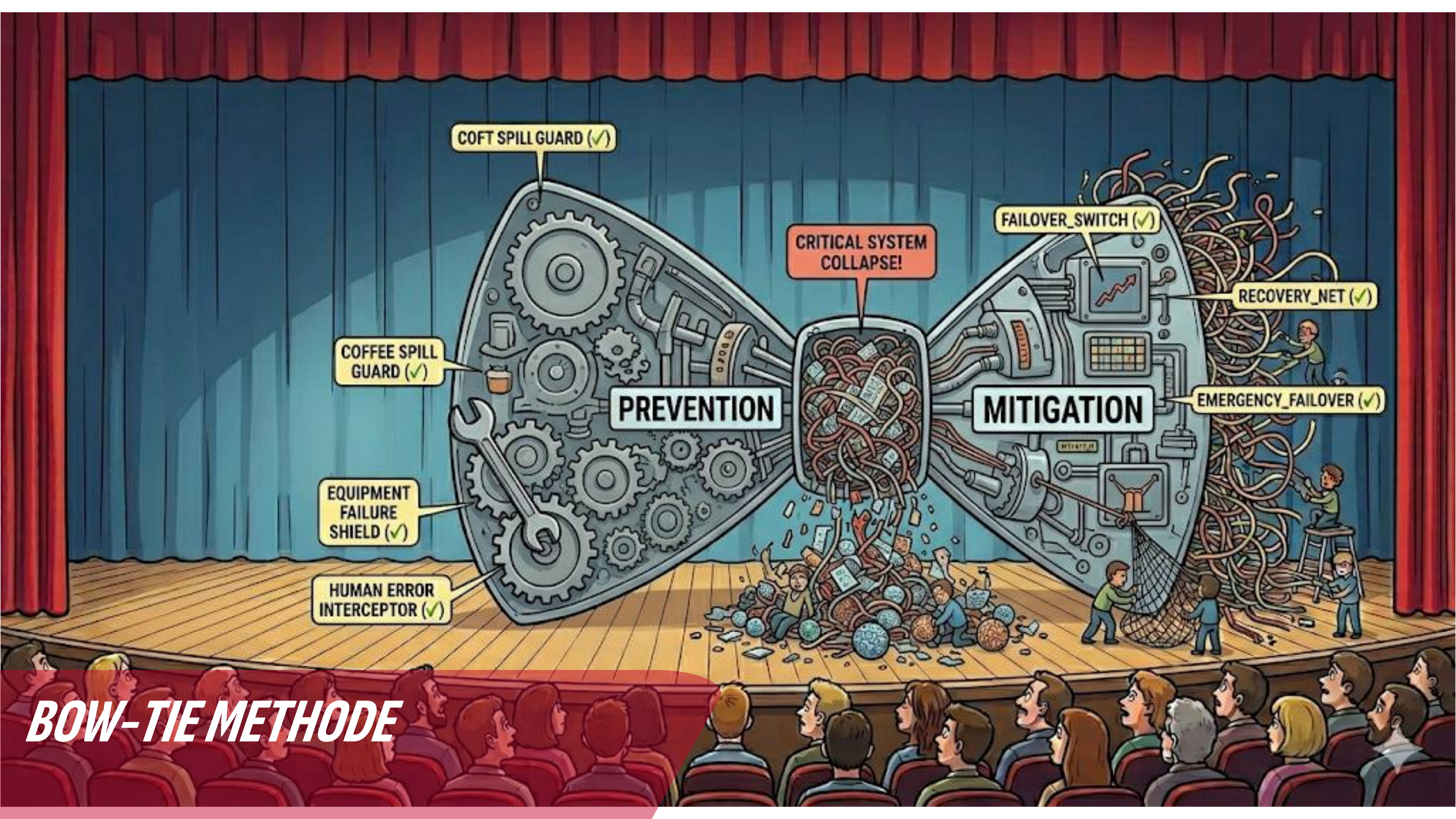
ISO 27005 | Risicocriteria

Voordat er begonnen wordt: definieer de meetlat

Je kunt risico's pas beoordelen als je weet wat acceptabel is. De risicocriteria:

- **Risicoscoreschaal:** hoe bereken je kans en impact?
 - (bijv. $1-5 \times 1-5 = 1-25$)
- **Risicobereidheid** (risk appetite):
 - welk risiconiveau accepteert de organisatie?
 - b.v. "Risico's met score ≥ 15 zijn altijd onacceptabel en vereisen directe actie"
- **Grenswaarden** per categorie:
 - de lat ligt hoger voor patiëntveiligheid dan voor reputatie
- **Wie** accepteert welk risico?
 - Geaccepteerde risico's $\geq$ *<bepaalde score>* moeten op *<x niveau>* worden goedgekeurd
- In de opdracht: definieer je eigen risicocriteria voordat je de matrix invult.

Zonder criteria kun je niet onderbouwen waarom een risico rood of groen is.



BOW-TIE METHODE

Bow-Tie | Risico's en maatregelen

Oorsprong uit de veiligheidskunde, nu breed toegepast in informatiebeveiliging

- De Bow-tie-methode is oorspronkelijk ontwikkeld in de chemische en nucleaire industrie om complexe veiligheidsrisico's inzichtelijk te maken.
 - De naam komt van de vorm: het diagram lijkt op een vlinderdas (ie: bow tie 😊).

Wanneer gebruik je Bow-tie?

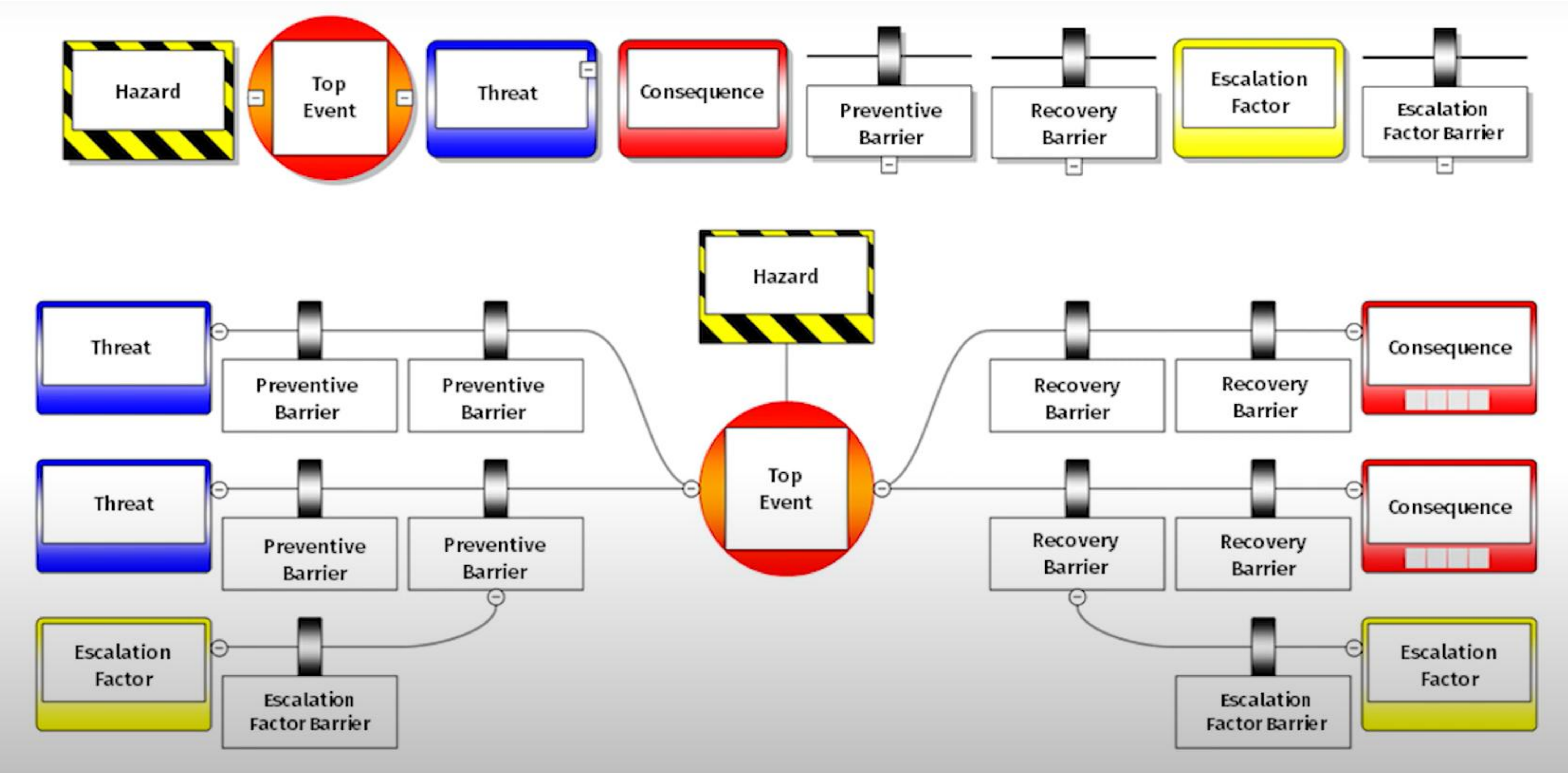
- Een specifiek, concreet risicoscenario doordenken, van oorzaak tot gevolg
- Aan stakeholders of auditors aantonen dat er zowel preventief als reactief nagedacht is
- Aanvulling op een risicomatrix
 - de matrix zegt hoe erg, de bow-tie zegt hoe dan en wat eraan te doen
- Ontwerpen of reviewen van beveiligingsmaatregelen in een systeem of proces

Bow-Tie: NEN-7510?

Oorsprong uit de veiligheidskunde, nu breed toegepast in informatiebeveiliging

- Bow-tie ondersteunt de eisen van NEN-7510-1 (6.1.2) (informatiebeveiligingsrisicoanalyse) en NEN-7510-2:
 - inzichtelijk te maken welke beheersmaatregelen (controls) als barrière fungeren
 - zowel preventief als corrigerend.

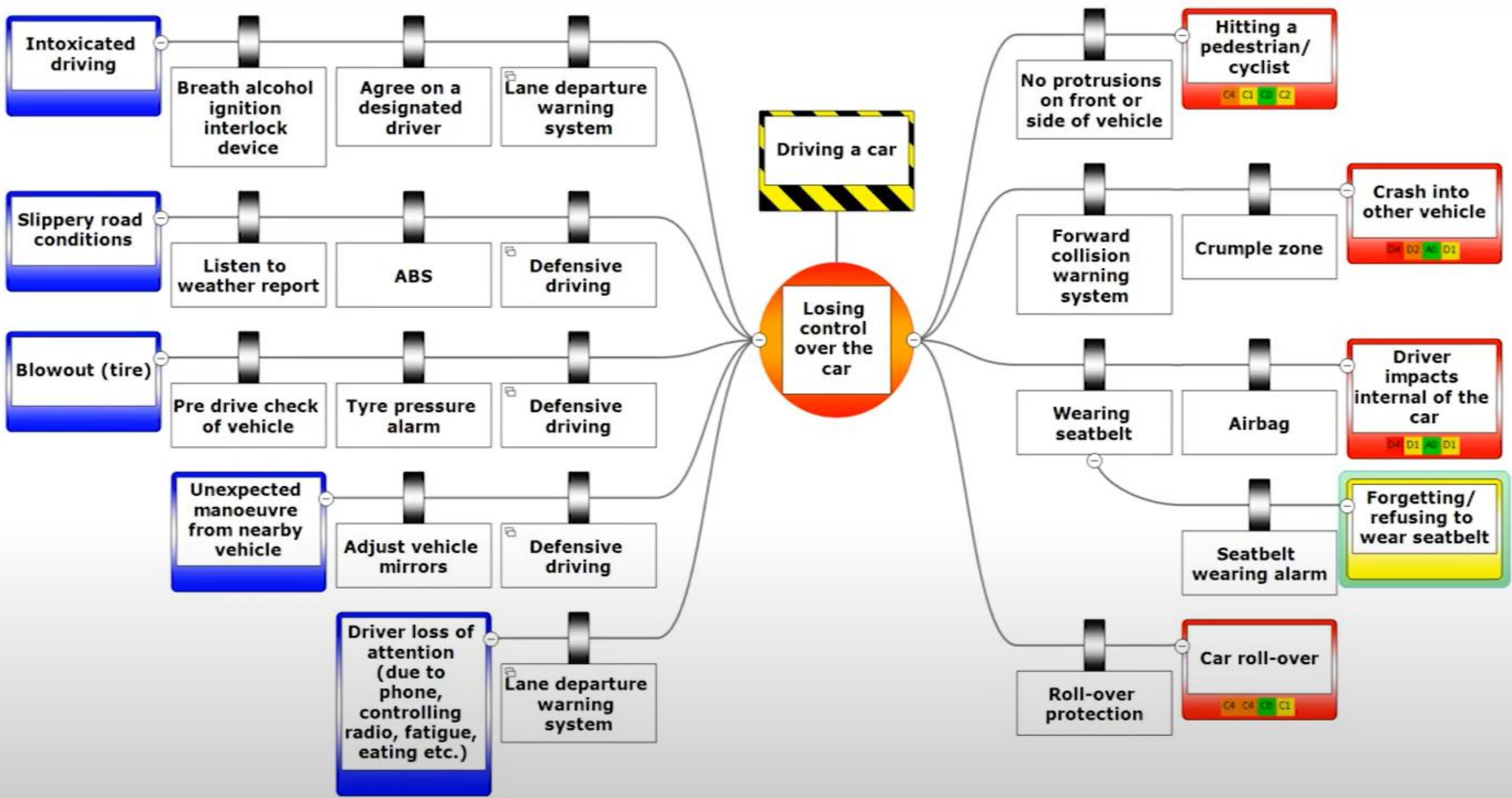
Bow-tie



Bow-Tie, terminologie

Element	Beschrijving	Doel
Top event	Het centrale incident (bijv. "ongeautoriseerde toegang tot FHIR-endpoint")	Definitie van wat je wilt voorkomen
Threats (links)	Oorzaken die kunnen leiden tot het top event	Identificeer aanvalsvectoren
Preventieve barrières	Controls die het top event voorkomen	Reduceren de kans
Consequences (rechts)	Gevolgen als het top event toch plaatsvindt	Bereid je voor op schade
Herstelbarrières	Controls die de schade beperken	Reduceren de impact

Bow-tie voorbeeld | Autorijden



Bow-Ie voorbeeld | Laptop

Top Event: Unauthorized access

Dreigingen en consequenties

L Laptop gestolen

M Open 'unlocked' laptop

M Gokken wachtwoord

H Trapt in phishing e-mail

LAPTOP

Unautho
rized
Access

Loss of integrity, availability and confidentiality



Wachtwoor
den gelekt **H**

Overnemen
webapplicati
es **H**

Laptop door-
verkopen **L**

Malware
infectie **H**

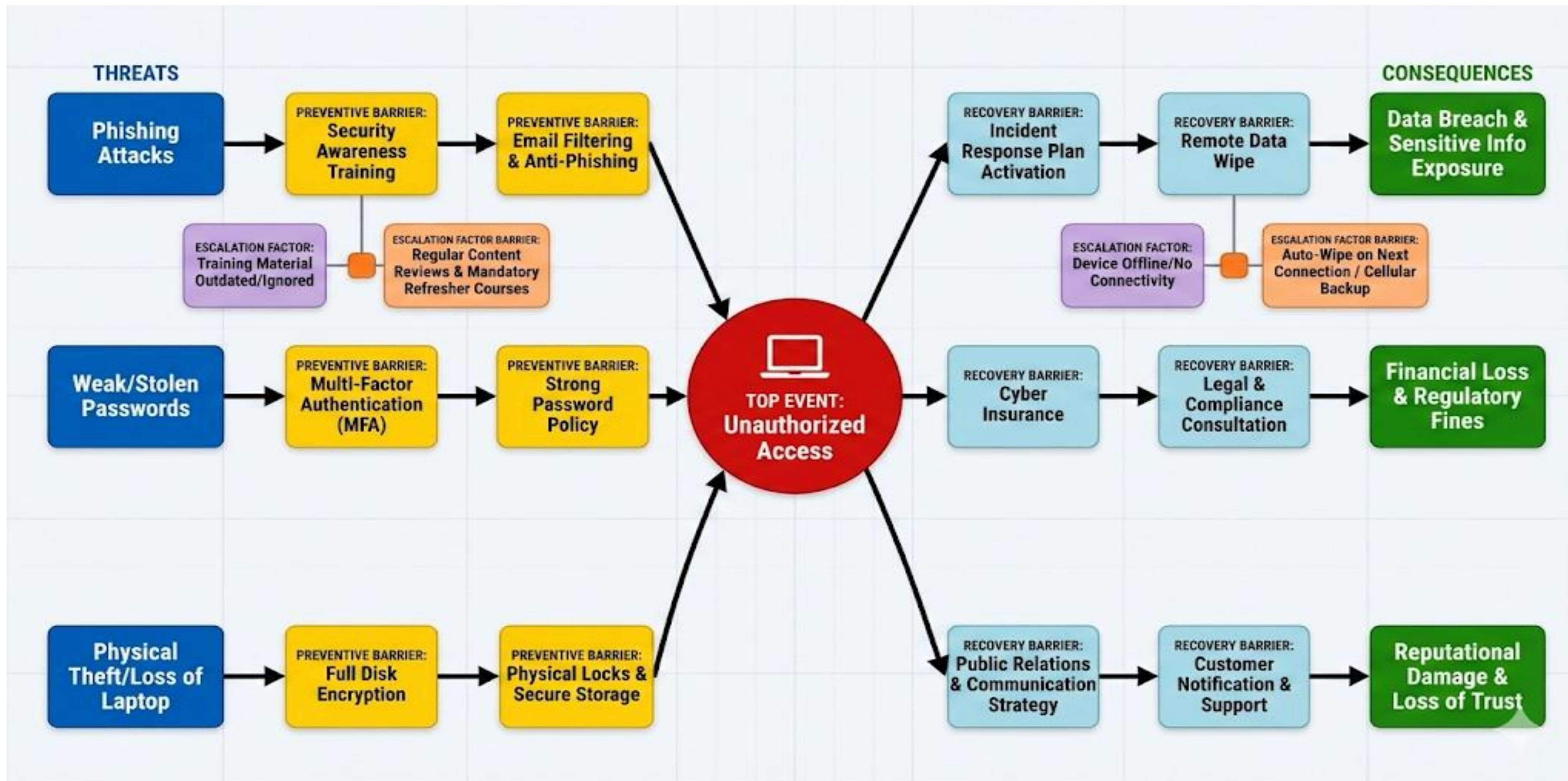
Identiteit
overnemen
(mail) **H**

Lekken
vertrouwelijke
documenten **H**

Bow-Tie voorbeeld | Laptop

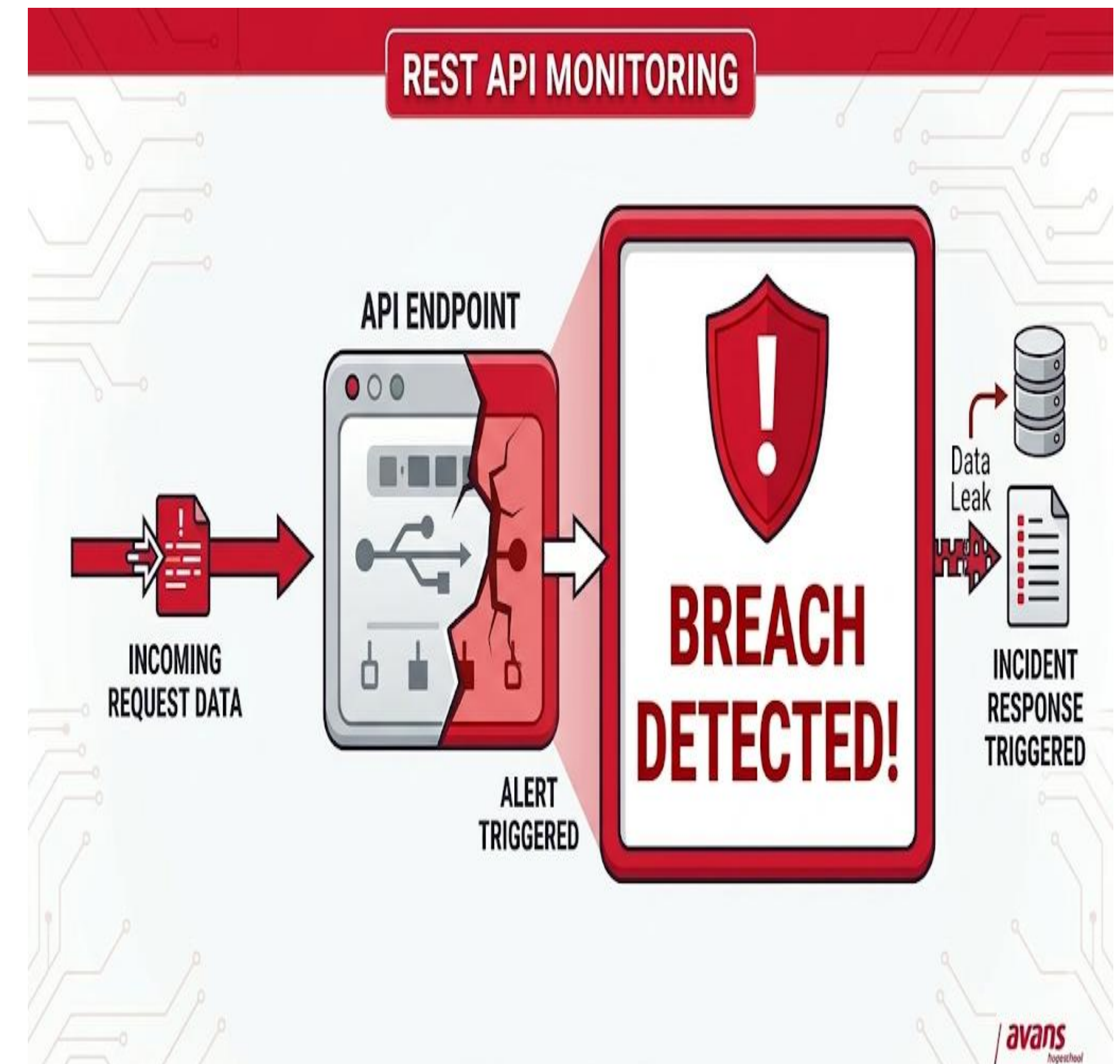
Top Event: Unauthorized access

Met maatregelen



Voorbeeld bow-tie FHIR2 module

- **Hazard:**
 - Aanwezigheid van herleidbare patientgegevens
- **Top event:**
 - Ongeautoriseerde toegang, bulk extractive gegevens via FHIR2 endpoint



Links: Threats & preventive barriers

"Hoe voorkomen we dat het incident gebeurt?"

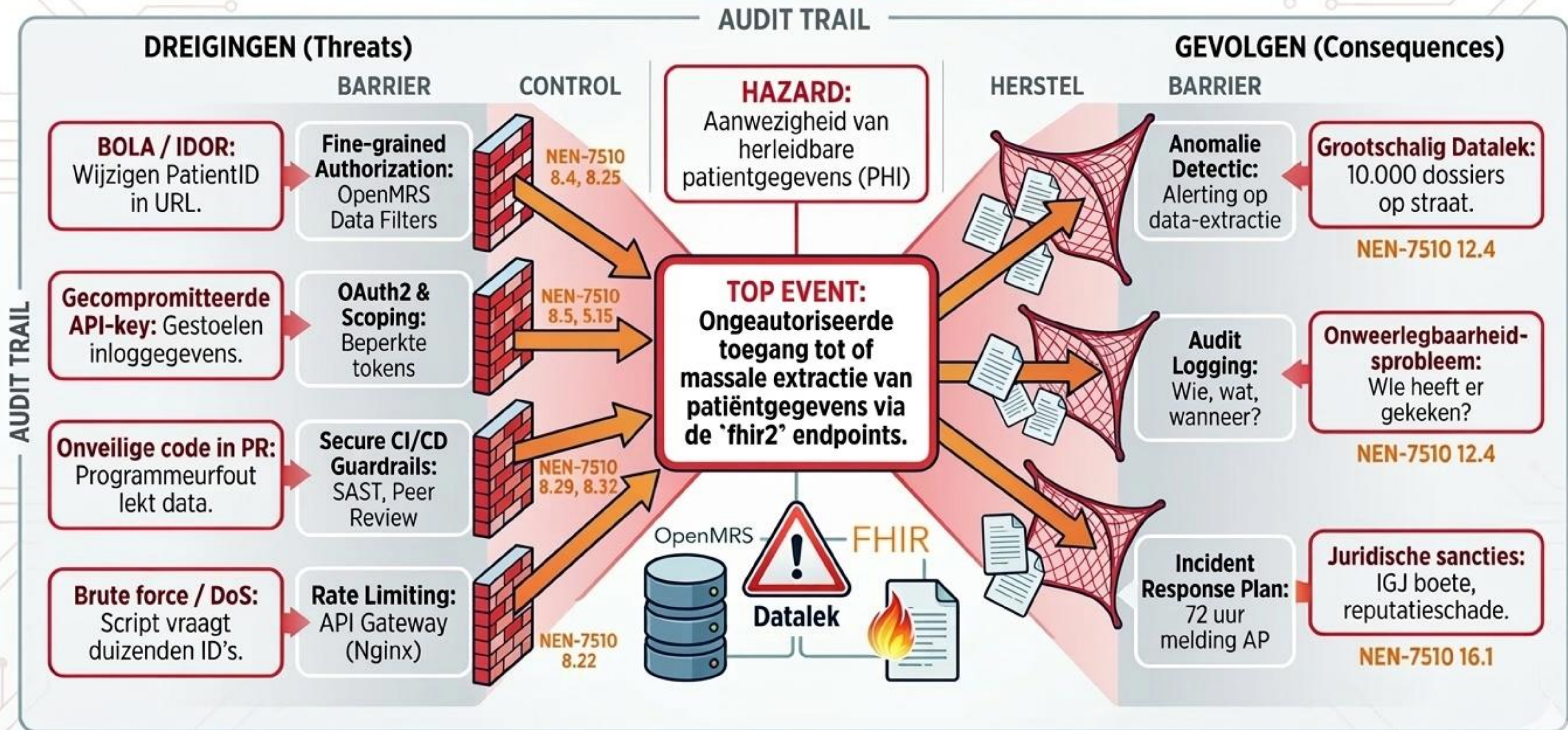
Dreiging (Threat)	Preventieve Barrière (De "Control")	Relatie NEN-7510:2024
BOLA / IDOR: Aanvaller wijzigt het PatientID in de URL om dossier van een ander op te vragen.	Fine-grained Authorization: Implementatie van het Data Filter mechanisme in de fhir2 module (alleen toegang tot toegewezen patiënten).	8.4 Toegangscontrole & 8.25 Beveiligde ontwikkeling
Gecompromitteerde API-key: Inloggegevens van een gekoppelde app liggen op straat.	OAuth2 & Scoping: Gebruik van kortstondige tokens met beperkte scopes (bijv. alleen 'read' op 'Observations', geen 'write').	8.5 Authenticatie & 5.15 Toegangscontrole
Onveilige code: Een programmeurfout in een nieuwe Pull Request lekt data.	Secure CI/CD Guardrails: Verplichte SAST-scans (Checkmarx/Snyk) en verplichte Peer Review voordat code naar main gaat.	8.29 Beveiligingstesten & 8.32 Wijzigingsbeheer
Brute force / DoS: Een script probeert duizenden ID's per seconde op te vragen.	Rate Limiting & Hardening: Configuratie van een API-gateway (bijv. Nginx/Kong) voor de fhir2 module die verkeer beperkt.	8.22 Netwerkbeveiliging

Rechts: Consequences & recovery barriers

“Het is misgegaan, hoe beperken we de schade?”

Gevolg (Consequence)	Herstel Barrière ("Control")	Relatie NEN-7510:2024
Grootschalig Datalek: 10.000 dossiers liggen op straat (AVG boete, reputatieschade).	Anomalie Detectie: Alerting die afgaat zodra er ongebruikelijk veel data-extractie plaatsvindt vanuit één account/IP.	8.15 Logging en monitoring
Onweerlegbaarheidsprobleem: We weten niet wie er gekeken heeft, dus kunnen we de patiënt niet informeren.	Audit Logging: Elke aanroep naar de fhir2 module wordt gelogd (wie, wat, wanneer) in een onveranderlijk logbestand.	8.15 Logging ("Niet gelogd = niet gebeurd")
Juridische sancties: Inspectie Gezondheidszorg (IGJ) legt sancties op wegens nalatigheid.	Incident Response Plan: Een getraind team dat binnen 72 uur het lek dicht en melding maakt bij de AP.	8.16 / 5.24 Beheer van informatiebeveiligingsincidenten
Gevolg (Consequence)	Herstel Barrière (De "Control")	Relatie NEN-7510:2024

ISO 27005 & NEN-7510 BOW-TIE ANALYSE: OPENMRS `fhir2` MODULE



Bow-tie tools

- OpenRisk: <https://openrisk.presight.com/bowtie/>
- Excel
- PowerPoint
- ...

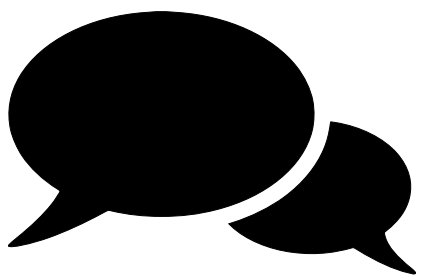
Breached... en nu?

Scenario:

De FHIR2-module heeft een BOLA-kwetsbaarheid die zes maanden onopgemerkt is misbruikt. Wat heb je nodig om de schade te reconstrueren?

- Welke logs heb je dan nodig? Zijn die er bij OpenMRS standaard?
- Wat zijn de AVG-verplichtingen bij een datalek?
- Wat is het verschil tussen een log die bewijst dat er ingelogd is en een log die bewijst wat er ingezien is?

Een preventieve maatregel die faalt zonder detectie is erger dan een maatregel die faalt mét detectie



Van risico analyse naar NEN-7510-2 controls

Risicoanalyse (ISO27005 / MAPGOOD / Bow-tie)		NEN-7510-2 control
Risico geïdentificeerd	→	Selecteer relevante control
Kans × Impact bepaald	→	Prioriteer implementatie
Aanpak gekozen	→	"Pas toe of leg uit"
Restrisico geaccepteerd	→	Documenteer in ISMS (deel 1)

Voorbeeld FHIR2 risico → control

Risico	Score	Control	Maatregel
BOLA/IDOR-aanval op patiëntdossiers	20 (K:4 × I:5)	8.4 Toegangscontrole broncode	Fine-grained authorization in code + code review
Gecompromitteerde API-key	15 (K:3 × I:5)	8.5 Authenticatie	OAuth2 met kortstondige scoped tokens
Onveilige code in PR	12 (K:3 × I:4)	8.29 Beveiligingstesten	SAST in CI-pipeline (CodeQL)
Ontbreken audit trail	16 (K:4 × I:4)	8.15 Logging	Immutable logging van alle API-calls

Opdrachten – OpenMRS module

- Met het gekozen OpenMRS project
- Beschrijf de context
 - Welke gevoelige gegevens worden verwerkt (met referenties)
 - Analyseer BIV (CIA)
- Definieer risico criteria
 - Score schaal, risk appetite / acceptance
 - Risicobereidheid en grenswaarden moeten vastgelegd worden

Deel 1 | Asset identificatie & threat modeling

- **Context:**

- Bestudeer de documentatie van de module

- **Taak:**

- Identificeer een aantal 'assets' binnen de module
 - B.v. Patient Obs, User Credentials, System Settings.

- **Vraag:**

- Welke hazards zijn het meest reëel voor de module?

Deel 2 | Maak een bow-tie van hazard

- **Context:**

- De gekozen OpenMRS module

- **Taak:**

- Kies een hazard
- Bedenk het top-event
- Maak de bow-tie
 - Analyseer welke NEN-7510:2024-2 controls van toepassing zijn
 - Neem zowel preventieve als correctieve maatregelen op
- Link het aan de 'audit mindset'
 - Niet gelogd == niet gebeurd!

Deel 3 | Risico evaluatie CI-CD

- **Context:**
 - CI-CD inrichting zoals tijdens / na vorig college ingericht
- **Taak:**
 - Maak een risico matrix
 - Maak bow-tie's
 - Neem ook escalation factors op

Lesson 4: HEALTHCARE INFORMATION SYSTEMS (HIS) RISK ASSESSMENT

ISO 27005
Organizational
Context Input

ISO 27005

(FAILED)

A MERGED APPROACH:
ISO 27005 & NEN-7510:2024
(A Powerful Team!)

Most FAILURE

NEN 7510:2024

NEN 7510:2024
Care Sector
Context Input

Failure -
(Underestimated
care provision)
(MISSED)

ISO 27005

NEN 7510:2024

PERIMETER
SECURITY

MULTI-FACTOR
AUTH (MFA)

ACCESS CONTROL
(LEAST PRIVILEGE)

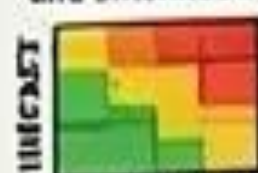
CYBER SECURITY
TRAINING

② IDENTIFY HIS RISKS:

- Assets (EHN Data, Medical Devices) [NEN/ISO]
- Threats (Phishing, Failure)
- Vulnerabilities

③ ANALYZE RISKS:

Assess impact
(to Patient Care,
to Data Privacy)
and Likelihood



④ EVALUATE RISKS:

Compare to internal
risk acceptance criteria
and regulatory
standards



⑤ EVALUATE RISKS:

Mitigation bypassed
or poorly implemented

⑥ TREAT RISKS:

Develop combined
Mitigation Measures

⑦ MONITORING:

No real-time monitoring
& poor incident response

REGULATORY FINE
(GDPR/AVG)

LEGAL
ACTION

BUSINESS
CONTINUITY PLAN

PATIENT HARM
(CLINICAL ERRORS)

REPUTATIONAL
LOSS

RISK WAS REAL:
When Checkboxes
Replaced Reality

VISUALIZING
HIS RISK:
THE BOW-TIE
METHOD

Integrates AVG Compliance
& HIS Beveiliging

TOTAL
COMPROMISE

TOT SLOT.

Vragen?

